UNIVERSIDAD COOPERATIVA DE COLOMBIA

VIGILADA MINEDUCACIÓN

MÓDULO CONTEXTO DE LA SEGURIDAD DE LA INFORMACIÓN

Rodrigo Arturo Carreño Vallejo

Profesor Especialización en Seguridad de la Información
Ingeniero de Sistemas Informáticos
Especialista en Gerencia de Proyectos en Telecomunicaciones
Especialista en Seguridad de la Información

SEMANA 1

Popayán Abril 2024

PROGRAMA DEL CURSO

Competencias previas: Conocimientos básicos en tecnologías de la información

Justificación: El contexto de seguridad de la información desde la óptica de los referenciales ISO/IEC 27001, ISO 20000-1 y la ISO 22301 especifica los requisitos necesarios para gestionar la información en todos los niveles de la organización garantizando la confidencialidad, la integridad y la disponibilidad de la información, de esta manera se mejora la productividad, eficiencia y eficacia de los procesos. También permite generar criterios de aplicación acordes con las necesidades de la organización en busca del mejoramiento continuo y la minimización de los riesgos.

Macro competencia: Formular alternativas de solución que permitan la seguridad en plataformas TIC, partiendo del conocimiento de las propias vulnerabilidades, hasta llegar a la implementación de mecanismos de detección, protección, defensa y mitigación de riesgos contra posibles amenazas y los distintos ataques que afectan la infraestructura tecnológica de una organización.

PROGRAMA DEL CURSO

ISO es la Organización Internacional de Normalización, (International Organization for Standardization)

IEC hace referencia a la Comisión Electrotécnica Internacional (International Electrotechnical Commission).

PROGRAMA DEL CURSO

Unidad de Competencia: Establecer los principales elementos de la seguridad de la información para identificar los objetivos, la clasificación de las amenazas y/o los incidentes de seguridad según estándares y normas vigentes.

Problema que resuelve: El riesgo en el manejo de la información la cual es vulnerable en las organizaciones, los esquemas ISO/IEC 27001, ISO/IEC 20000 y la ISO 22301 permiten preservar la confidencialidad, la integridad y la disponibilidad de la información mediante un manejo adecuado, garantizando la continuidad del negocio.

Temas:

Implementar elementos de la seguridad de la información en un contexto real.
Seleccionar los elementos de la seguridad de la información para la clasificación de las amenazas.
Analizar los elementos de la seguridad de la información.

Antecedentes y desarrollo de las normas de Gestión de la Seguridad



Definiciones de la seguridad de la información

Introducción a la seguridad de la Información:

En nuestros días, hablar de información no es ajeno a nuestra cotidianidad debido a que constantemente la estamos enviando o recibiendo desde diferentes fuentes: la casa, la radio, la televisión, redes sociales y los diferentes medios de comunicación.

No obstante, el concepto de información ha adquirido una singular importancia tanto en el entorno empresarial como en el entorno personal, de manera que se nos hace necesaria protegerla para concebir un ambiente de tranquilidad en las transacciones que realizamos.
¿A qué se debe esta situación? ¿Por qué escuchamos y hablamos de temas como protección de datos personales, hackers, entre otros conceptos relacionados, independientemente del rol que ejercemos en nuestra empresa?

Para responder a estos cuestionamientos se hace necesario aclarar dos conceptos fundamentales:
Información y Seguridad.

Información, cuyo equivalente latín es indicium, para la Real Academia Española significa: “Comunicación o adquisición de conocimientos que permiten ampliar o precisar los que se poseen sobre una materia determinada” (RAE, 2017). Es decir, desde el punto de vista semántico podemos afirmar que la información brinda conocimiento y, por tanto, nos permite ampliar el juicio que tenemos sobre un tema determinado, permitiendo que lo comprendamos a un nivel superior.

Introducción a la seguridad de la Información:

Sin embargo, no todo lo que recibimos como información cumple cabalmente esta definición, gracias al volumen que se maneja en los diferentes medios, la diversidad de opiniones válidas que pueden existir entre un individuo y otro, su origen y tiempo de producción. En otras palabras, el concepto de información se ve afectado por los actores mismos de la comunicación (emisor, receptor, mensaje, canal).

Es por esto por lo que referentes de clase mundial, como lo son las normas internacionales, han estado de acuerdo en que la información debe evaluarse como aquello que genera o posee valor para el destinatario, sin desconocer la naturaleza misma del conocimiento que brinda (ISO, 2009).

Veamos la definición propuesta por la norma ISO 27001:2022 con respecto al concepto de información:

“Todo aquel conjunto de datos organizados en poder de una entidad que posean valor para la misma, independientemente de la forma en que se guarde o transmita (escrita, en imágenes, oral, impresa en papel, almacenada electrónicamente, proyectada, enviada por correo, fax o e-mail, transmitida en conversaciones, etc.), de su origen (de la propia organización o de fuentes externas) o de la fecha de elaboración (ISO, 2022)”.

Introducción a la seguridad de la Información:

En este sentido, podemos identificar que la información tiene 4 elementos fundamentales, que se presentan en la siguiente tabla:

Tabla 1. Elementos de la información

DATOS:	ORDEN:	VERACIDAD:	VALOR:
Emitidos o recibidos. Eje fundamental de la información	Es la lógica; lo que le da sentido	La fuente es confiable	Utilidad, el fin con el que se usa
			
Figura 1. Datos *Fuente:* Geralt (s.f.)	**Figura 2. Orden** *Fuente:* Geralt (s.f.)	**Figura 3. Veracidad** *Fuente:* Geralt (s.f.)	**Figura 4. Valor** *Fuente:* fancycrave1 (s.f.)

Fuente: elaboración propia

El objetivo de esta tabla es presentar los elementos fundamentales que debe cumplir la información y establecer algún tipo de secuencia, es decir primero están los datos, estos se ordenan para que tengan sentido, se valida su procedencia (que sea confiable) y por último adquieren valor para una empresa por el modo como se usan.

Clasificación de la información:

Las organizaciones se han preocupado por todo lo referente a la información que producen y reciben; por tal motivo, se ha clasificado de acuerdo con su valor, los requisitos legales que deba cumplir, la sensibilidad y el nivel de criticidad que tiene para una empresa.

Es decir, no basta con identificar la información, sino que es necesario cuantificar el valor que tiene para la organización con el fin de distinguir qué tan sensible es dicha información a la pérdida, la divulgación o falta de disponibilidad.

Sin embargo, estos no son los únicos criterios existentes para clasificar la información, puesto que el desarrollo de políticas estatales, tales como protección de datos personales, ha permitido que se amplíen los niveles de clasificación.

No existen reglas estrictas sobre los niveles de clasificación que una organización debería utilizar, lo cual depende más de sus necesidades; no obstante, en la siguiente tabla se sugiere una clasificación general, la cual suele utilizarse en la industria (Harris, 2013).

Clasificación de la información:

Tabla 2. Clasificación de la información

Clasificación	Definición	Ejemplo
Pública	Información que puede ser divulgada sin que ocasione perjuicios a la organización o una persona. Preferiblemente no se divulga.	Cantidad de personal trabajando en un proyecto.
Privada	Información personal que no debe ser divulgada. Su difusión puede afectar negativamente a la empresa o persona.	Información médica.
Confidencial	Información que solo debe conocer la compañía. Esta información se encuentra exenta de transmisión de acuerdo con las leyes y regulaciones donde se utilice. Su divulgación puede afectar negativamente a la empresa.	Códigos de programación.
Sensible	Información que requiere un cuidado especial para garantizar la integridad y confidencialidad, protegiéndola de modificación o eliminación no autorizada.	Información financiera.
No clasificada	La información no es sensible ni se encuentra clasificada.	Manuales de dispositivos, como computadores.
Sensible pero no clasificada	La información tiene un nivel de secreto menor que la información sensible, puesto que si se revela podría no ocasionar daños.	Respuesta de los puntajes de algún *test*.
Secreta	Información que no debe ser revelada, pues podría generar daños a nivel nacional. Esta clasificación suele utilizarse en ambientes militares.	Planes de despliegue de tropas.
Ultra secreta	Información que no debe ser revelada, pues tiene implicaciones perjudiciales a nivel nacional. Esta clasificación suele utilizarse en ambientes militares.	Información de satélites espía.

Fuente: Harris (2013)

Procedimientos de clasificación de datos:

La clasificación de la información es el primer paso para iniciar una gestión eficiente de esta y, de esta forma, requiere la definición de actividades que sigan una secuencia lógica.

A continuación, acorde con Harris (2013), se propone un paso a paso de las actividades a seguir para alcanzar el objetivo de organizar y clasificar correctamente la información:

1. Definir los niveles de clasificación: puede utilizarse alguna norma o buena práctica ya establecida o la empresa los puede definir, según lo considere necesario.

2. Especificar los criterios que determinan cómo se clasifican los datos: esto varía de una organización a otra, por lo cual se deben unificar los criterios para su definición.

3. Identificar los dueños de la información dentro de la empresa: estas personas serán las encargadas de clasificar la información de acuerdo con los niveles y criterios establecidos.

Procedimientos de clasificación de datos:

4. Identificar quien actuará como custodio de los datos: quién será el responsable de preservar los datos y los niveles de seguridad que se han establecido.

5. Identificar los mecanismos de protección: aquí se pueden utilizar herramientas, como el análisis de riesgos, para cumplir con dicho objetivo.

6. Documentar cualquier excepción que aplique a lo anteriormente establecido: en caso de que conciernan dichas excepciones.

7. Indicar los métodos que pueden utilizarse para transferir la custodia de la información: solo en caso de requerirse.

8. Crear un procedimiento para revisar periódicamente la clasificación y propiedad: esto implica comunicar los cambios a los afectados (dueños y custodios).

Procedimientos de clasificación de datos:

9. Difundir los procedimientos para desclasificar los datos.

10. Sensibilizar al personal sobre el uso de la información para que este entienda cómo manejar la información en los diferentes niveles de clasificación definidos.

Definición de informática:

Según la Real Academia de la Lengua Española, informática se define como el “conjunto de conocimientos científicos y técnicas que hacen posible el tratamiento automático de la información por medio de computadoras” (RAE, 2017).

Por tratamiento de la información podemos considerar su almacenamiento, procesamiento y transmisión.

Definición de información:

Teniendo claro el concepto de información, es fundamental comprender y asimilar el concepto de seguridad.

Seguridad, viene del latín securitas, que significa “certeza, sin temor a preocuparse”. Desde este origen etimológico latino, podemos establecer que se encuentra conformado por el vocablo securus (cuya definición acabamos de mencionar) y el sufijo dad, significa “cualidad”.

La Real Academia Española lo define como “cualidad de seguro” (RAE, 2017), siendo la definición de seguro: “Libre y exento de riesgo, cierto, indubitable, firme o bien sujeto, que no falla o que ofrece confianza” (RAE, 2017). El riesgo, en términos generales, puede entenderse como la proximidad de un daño, afectación por una situación, persona o elemento.

De acuerdo con lo anterior, se puede afirmar que seguridad es la cualidad de un objeto de estar libre de riesgo, ser confiable y certero.

Al igual que el término de información, la seguridad presenta diferentes clasificaciones con relación a los aspectos de la vida cotidiana que involucra, como puede ser la seguridad de las personas en el entorno laboral, de los alimentos, de los productos, del negocio, de la información, entre otros.

Seguridad de la información y seguridad informática: ¿Conceptos iguales o diferentes?



Seguridad de la información y seguridad informática: ¿Conceptos iguales o diferentes?

Hemos realizado un recorrido por los conceptos de información, informática y seguridad. Ahora bien, es importante asociarlos para establecer la diferencia entre los conceptos de seguridad informática y seguridad de la información.

Es claro que seguridad implica una cualidad, que la información hace referencia a la generación de valor y que la informática es una ciencia que permite el tratamiento automático de información (datos) por medio de sistemas computacionales.

Por lo tanto, la seguridad informática implica garantizar que los sistemas computacionales que se utilizan para el procesamiento de datos se encuentren libre de riesgos, que sean confiables y ciertos. La seguridad de la información hace referencia al conjunto de medidas que se deben aplicar para garantizar que, independientemente del medio de trasmisión, tipo de información, nivel de criticidad y valor que tenga para una organización, la información esté exenta de riegos para que sea certera y confiable.

Seguridad de la información y seguridad informática: ¿Conceptos iguales o diferentes?

La seguridad de la información tiene un sentido más amplio que el término de seguridad informática y está orientada a gestionar eficientemente los recursos tecnológicos, físicos, humanos y procedimentales que aportan utilidad a la empresa para su operación, con el fin de que la afectación de esta sea mínima por daños ocasionados, consciente o inconscientemente, por terceros, fuera o dentro de la organización.

Partiendo de dicho concepto, se han desarrollado buenas prácticas, recomendaciones y estándares internacionales que brindan un marco conceptual en el tema de seguridad de la información y que facilitan su gestión.

Uno de ellos es la norma **ISO 27001: 2022** (versión más reciente), la cual expresa el término de seguridad de la información como la preservación de la **confidencialidad**, **integridad** y **disponibilidad** de la información, así como de los sistemas implicados en su tratamiento dentro de una organización.

Para comprender a profundidad la definición anterior, es importante conocer los términos descritos, que en el mundo de la seguridad de la información se conocen como los principios de seguridad de la información.

Seguridad de la información y seguridad informática: ¿Conceptos iguales o diferentes?

Disponibilidad: La información debe ser utilizable por quien la necesita en todo momento.

Confidencialidad: La información debe ser transferible solo entre los entes autorizados.

Integridad: La información debe ser confiable y certera, sin alteraciones de ningún tipo.

Así pues, podemos concluir que la seguridad de la información es el conjunto de medidas tanto preventivas como correctivas que ayudan a las organizaciones a garantizar la **disponibilidad**, **integridad** y **confidencialidad** de la información, con el fin de minimizar el impacto que cualquier riesgo pueda generar sobre esta. La seguridad de la información incluye a la seguridad informática, por lo cual es más apropiado utilizar el término seguridad de la información para referirse a la protección de activos de información cuya esencia no sea exclusivamente tecnología. Sin embargo, frente a esta discusión hay múltiples opiniones y todo deriva de la traducción desde el idioma inglés al español.

Otras definiciones de interés en seguridad de la información:

Existen varios términos alrededor de la seguridad de la información que se utilizan indistintamente y los cuales es importante aclarar, principalmente para una buena gestión de la seguridad dentro de las organizaciones, la cual se logra evitando cualquier elemento que afecte a un activo de información, como se muestra en la figura 5.



Figura 5. Control de virus
Fuente: Kalhh (s.f.)

En esta imagen se evidencia la relación entre los conceptos vulnerabilidad, amenaza, riesgo y control, puesto que un virus (amenaza) ha sido detectado por el antivirus (control), evitando daño en el funcionamiento (riesgo) del computador (activo). Estos términos se amplían a continuación.

Otras definiciones de interés en seguridad de la información:

Activo de información: Todo aquello que tiene un valor para la empresa (ISO, 2009), especialmente monetario, como las personas, su conocimiento, sistemas, etc.



Figura 6. Activos de información

Fuente: Bloomua (s.f.)

Vulnerabilidad: Falla propia o intrínseca del activo por su naturaleza o por la ausencia de controles y que se considera una debilidad del activo. Esta falla puede ser explotada por una amenaza y convertirse en un riesgo. Las vulnerabilidades se consideran sobre el software, el hardware, los procedimientos o los mismos recursos humanos.

Otras definiciones de interés en seguridad de la información:

Exposición: Consecuencia peligrosa que genera una vulnerabilidad y por la cual esta puede ser explotada.

Amenaza: Peligro potencial externo al activo. A diferencia de la vulnerabilidad, que es propia de la naturaleza del activo, las amenazas dependen de la exposición que pueda tener el activo.

Riesgo: Probabilidad de que una amenaza explote una vulnerabilidad y el impacto que esta situación genera a nivel legal, comercial, de imagen, etc.

En la siguiente figura se puede observar que el computador era vulnerable por el control de acceso que tenía, razón por la que quedó expuesto y la amenaza aprovechó la vulnerabilidad, materializándose el riesgo, cuyo impacto fue económico (robo de dinero).

Otras definiciones de interés en seguridad de la información:



Figura 7. Riesgo materializado

Fuente: Jemastock (s.f.)

Otras definiciones de interés en seguridad de la información:

Control: Elemento que se utiliza para mitigar un riesgo. Dependiendo del activo, su clasificación y nivel de riesgo, el control puede ser administrativo, técnico o físico y se utiliza para disuadir a un posible atacante, prevenir la ocurrencia de un incidente, o identificar, corregir y restaurar si el incidente ya ha ocurrido.

La definición de seguridad de la información se encuentra influenciada por diferentes entidades mundialmente reconocidas, las cuales concuerdan en que el término implica mantener libre de riesgo aquello que tiene valor para una empresa, sin importar el medio por el cual se transmite, origina o recibe. En otras palabras, la seguridad de la información hace referencia a garantizar la disponibilidad, integridad y confidencialidad de la información. Para lograrlo es fundamental definir el proceso de clasificación de la información, incluyendo la manera en que dicho proceso se mantendrá actualizado y la identificación de vulnerabilidades, amenazas y riesgos asociados a la información, para aplicar controles suficientes que eviten daños en las empresas.

Objetivos de la seguridad de la información:

Hasta aquí, hemos avanzado en la definición de conceptos claves que se utilizan en seguridad de la información. Conociendo estas definiciones, podemos entender la importancia de la seguridad de la información en las organizaciones, desde el punto de vista de los objetivos que debe cumplir; garantizar la en un entorno corporativo no solo implica definir controles que se aplican una única vez, sino que es un proceso reiterativo y dinámico, que requiere actualización constante por parte de quienes intervienen en el proceso, teniendo como base los objetivos que se esperan alcanzar. Dichos objetivos se pueden resumir en:

- Asegurar el adecuado uso de los recursos (de cualquier tipo), las aplicaciones, y los sistemas, clasificándolos en activos de información con el nivel de criticidad que corresponda según la organización.

Objetivos de la seguridad de la información:

- Analizar las vulnerabilidades y amenazas a las cuales está expuesto un activo, para la correcta identificación de riesgos y sus respectivos controles que minimicen el impacto si un riesgo llega a materializarse.

- Gestionar correctamente los incidentes de seguridad que puedan presentarse, de tal manera que se realicen las respectivas correcciones, una vez ocurra el incidente, y lograr la correcta recuperación de la operación.

- Cumplir el marco legal, con los requisitos establecidos a nivel de empresa, en lo referente a seguridad de la información y de acuerdo con el país o el sector en el que se desempeña la operación de la empresa.

Buenas prácticas, modelos y marcos para el cumplimiento de los objetivos de la seguridad de la información

Diferentes organizaciones alrededor del mundo han desarrollado sus propias prácticas para la gestión de la seguridad de la información, cuyo propósito es cumplir los objetivos identificados anteriormente, los cuales permiten controlar los riesgos, gestionar eficientemente los procesos y alcanzar un desarrollo empresarial sostenible.

A continuación, se hace un desglose sencillo de buenas prácticas, estándares y marcos de referencia en seguridad de la información, clasificados de acuerdo con el enfoque que le han brindado sus creadores (Harris, 2013).

Desarrollo del programa de seguridad: Normas internacionales de la serie ISO / IEC 27000 sobre cómo desarrollar y mantener un SGSI desarrollado por ISO e IEC. Han sido reconocidas por la industria la gestión de seguridad.

Buenas prácticas, modelos y marcos para el cumplimiento de los objetivos de la seguridad de la información

Desarrollo de arquitectura empresarial

- **Marco de arquitectura empresarial Zachman Framework:** Utilizado para definir y comprender un entorno empresarial; desarrollado por John Zachman.

- **Marco de arquitectura TOGAF Enterprise:** Utilizado para definir y comprender un entorno empresarial; desarrollado por The Open Group.

- **Marco de arquitectura del Departamento de Defensa de DoDAF EE. UU.:** Asegura la interoperabilidad de los sistemas para cumplir los objetivos de la misión militar.

- **Marco de arquitectura MODAF:** Utilizado principalmente en el apoyo militar a misiones realizadas por el Ministerio de Defensa británico.

Buenas prácticas, modelos y marcos para el cumplimiento de los objetivos de la seguridad de la información

Desarrollo de la arquitectura empresarial de seguridad

- **Marco SABSA:** Arquitectura de seguridad empresarial basado en el riesgo de mapas de iniciativas comerciales, similares al marco Zachman.

Desarrollo de controles de seguridad

- **CobiT:** Conjunto de objetivos de control para la gestión de TI desarrollado por la Asociación de Auditoría y Control de Sistemas de Información (ISACA) y el IT Governance Institute (ITGI)

- **SP 800-53:** Conjunto de controles para proteger los sistemas federales de EE. UU., elaborados por el Instituto Nacional de Estándares y Tecnología (NIST).

Buenas prácticas, modelos y marcos para el cumplimiento de los objetivos de la seguridad de la información

Gobierno corporativo

- **COSO:** Conjunto de controles corporativos internos para ayudar a reducir el riesgo de fraude financiero, desarrollado por el Comité de Patrocinio Organizaciones (COSO) de la Comisión Treadway.

Gestión de proceso

- **Procesos ITIL:** Para permitir la gestión de servicios de TI; desarrollados por el Oficina de Comercio Gubernamental del Reino Unido.

- **Estrategia de gestión Six Sigma Business:** Desarrollada por Motorola con el objetivo de mejorar los procesos comerciales.

Buenas prácticas, modelos y marcos para el cumplimiento de los objetivos de la seguridad de la información

Gestión de proceso

- **Proceso de Integración del Modelo de Madurez de Capacidades (CMMI):** Modelo de mejora desarrollado por Carnegie Mellon.



Mapa de Procesos Universidad Cooperativa de Colombia
Acuerdo No 025 de 2021

Buenas prácticas, modelos y marcos para el cumplimiento de los objetivos de la seguridad de la información



Buenas prácticas, modelos y marcos para el cumplimiento de los objetivos de la seguridad de la información

PROCESOS ESTRATÉGICOS: Conjunto de procesos encaminados al cumplimiento del Marco de gestión institucional y de los objetivos institucionales.

Siendo para la Universidad Cooperativa de Colombia los siguientes procesos Estratégicos:

- *Gestión de la estrategia*
- *Gestión del mejoramiento continuo*
- *Gestión de la identidad*

PROCESOS MISIONALES: Procesos esenciales de la institución, generadores de valor, encargados de estructurar la ventaja competitiva.

Siendo para la Universidad Cooperativa de Colombia los siguientes procesos Misionales:

- *Enseñanza*
- *Investigación, innovación y creatividad*
- *Vinculación con contextos nacionales e internacionales*

PROCESOS DE SOPORTE ADMINISTRATIVO: Procesos que gestionan tangibles e intangibles en la institución, con el ánimo de brindar soporte a su desarrollo y sostenibilidad.

Siendo para la Universidad Cooperativa de Colombia los siguientes procesos de soporte:

- *Gestión administrativa*
- *Gestión del servicio*

El mapa de procesos contempla los atributos institucionales, que, aunque no son considerados un proceso, se establecen como elementos diferenciadores de la universidad y para los cuales, los procesos contribuyen a su fortalecimiento.

ARTÍCULO SEGUNDO: Adoptar las siguientes definiciones:

Gestión por procesos: Es la forma de gestionar los procesos de forma estructurada buscando su mejora continua, orientada a las necesidades de los grupos de interés.

Mapa de procesos: Representación gráfica que permite identificar el funcionamiento y organización de la Universidad en la generación de valor a los grupos de interés.

Procesos: Conjunto de actividades que interactúan para generar valor y transforma los elementos de entrada en resultados.

Estructura de proceso: Corresponde a los componentes que hacen parte de la Gestión por Procesos, es decir, agrupación y/o categorización del conjunto de actividades, así como los documentos que se elaboran dentro de estas. Por ejemplo, caracterización, procedimientos, guías, etc.

Procedimientos: Constituyen la forma específica para llevar a cabo un proceso.

ARTICULO TERCERO: El presente acuerdo deroga expresamente la Resolución 621 de 2014.

Buenas prácticas, modelos y marcos para el cumplimiento de los objetivos de la seguridad de la información

Si ya se ha seleccionado un referente, ¿cómo implementarlo?

Existen una serie de herramientas utilizadas en las diferentes normas, modelos, buenas prácticas y marcos de seguridad de la información, que facilitan el cumplimiento de los objetivos de esta y, por tanto, contribuyen en la adopción de cualquier referente.

Estas herramientas suelen distinguirse por estar orientadas al cumplimiento estratégico o táctico de los objetivos. A continuación, se presentan sus definiciones, alcances y nivel de importancia en seguridad de la información.

Buenas prácticas, modelos y marcos para el cumplimiento de los objetivos de la seguridad de la información

Políticas

Es una declaración de obligatorio cumplimiento, aprobada por la alta gerencia, que define el papel de la seguridad de la información dentro de la organización. La aprobación de la alta gerencia incluye la definición del proceso a seguir para establecer el programa de seguridad y todo lo que este debe contener, como los objetivos, responsabilidades y el valor estratégico y táctico de la seguridad. Esta política debe abordar leyes aplicables, regulaciones, necesidades, problemas y/u oportunidades a nivel de seguridad de la organización y del nivel de riesgo que se espera aceptar, y debe indicar las actividades futuras que se deben ejecutar, en términos de seguridad, en toda la organización (Harris, 2013).

Estándares

Se refieren a actividades, acciones o reglas obligatorias. Los estándares pueden apoyar y reforzar la dirección a una política. Los estándares de seguridad pueden especificar cómo se usarán los productos de hardware y software; también se pueden usar para indicar el comportamiento esperado del usuario.

Buenas prácticas, modelos y marcos para el cumplimiento de los objetivos de la seguridad de la información

Estándares

Proporcionan un medio para garantizar que las tecnologías específicas, las aplicaciones, los parámetros y los procedimientos se implementen de manera uniforme (estandarizada) en toda la organización (Harris, 2013).



Figura 8. Relación de herramientas de acuerdo con el cumplimiento de objetivos

Fuente: elaboración propia

Buenas prácticas, modelos y marcos para el cumplimiento de los objetivos de la seguridad de la información

La idea es representar que las herramientas hacen parte de la cadena de documentación, siendo el nivel más bajo los procedimientos, pero indicado que tanto estándares, recomendaciones y procedimientos son de orden táctico.

Línea base

El término línea base se refiere a un punto en el tiempo que actúa como referencia para cambios futuros y también se utiliza para establecer el nivel mínimo de protección requerido. En seguridad, se pueden definir líneas base por grupo de activos identificados, por sistemas etc., lo que indica la necesidad de configuración y el nivel de protección que se le brindará según su criticidad. Las mediciones futuras que se realicen para determinar el cumplimiento de controles tendrán como punto de referencia la línea base (Harris, 2013).

Buenas prácticas, modelos y marcos para el cumplimiento de los objetivos de la seguridad de la información

Las recomendaciones

Son acciones sugeridas y guías operativas para usuarios, personal de TI, personal de operaciones y otros, cuando no se aplica una norma específica. Mientras que los estándares son normas de obligatorio cumplimiento, las recomendaciones son sugerencias con enfoques generales que brindan la flexibilidad necesaria para circunstancias imprevistas (Harris, 2013).

Los procedimientos

Son actividades completamente detalladas y definidas paso a paso que indican lo que se debe realizar para lograr un objetivo determinado. Las actividades establecidas en los procedimientos pueden ser desarrolladas por usuarios finales, personal de TI, directivos, personal de operaciones, proveedores y clientes, entre otros, cuya intervención sea indispensable para alcanzar el objetivo. Los procedimientos detallan cómo la política, los estándares y las directrices se implementarán realmente en un entorno operativo. Deben ser lo suficientemente detallados para ser comprensibles y útiles para un grupo diverso de personas. Se consideran el nivel más bajo en la cadena de documentación porque están más cerca de los activos de información (en comparación con las políticas) (Harris, 2013).

EN SINTESIS

El objetivo de la seguridad de la información es garantizar la disponibilidad, integridad y confidencialidad de esta. Para lograrlo, las organizaciones cuentan con diferentes referentes aceptados a nivel mundial y que hacen uso de herramientas, tales como procedimientos, recomendaciones, definición de líneas base, estándares y políticas, que facilitan su adopción.



Antecedentes y desarrollo de las normas de Gestión de la Seguridad

—¿A qué te dedicas?

- Especialista en seguridad

—¡Qué interesante! ¿Cuéntame más cosas?

- ¿De mi vida o de la tuya?



Los principios de la seguridad de la información: Eje de estudio en el análisis de riesgos

Introducción

En las diapositivas anteriores, determinamos conceptos claves en torno a la seguridad de la información, desde el desglose del término y las diferencias con respecto a la seguridad informática hasta las referencias internacionales y herramientas que utilizan dichas referencias para la gestión de la seguridad de la información.

Vamos a ampliar algunos conceptos fundamentales que son pilares para los diferentes roles que se pueden ejercer en el ambiente de la seguridad de la información y que son la base de toda la especialización.

Activos

Como hemos mencionado, la información es todo aquello que genera valor para una organización. Ese valor se ve representado en elementos tangibles o intangibles denominados activos. Decimos que son tangibles o intangibles porque contamos con evidencia real de su existencia. Por ejemplo, el conocimiento o know how tiene gran importancia para las organizaciones. Sin embargo, es un elemento intangible, que debe ser considerado dentro de la identificación de activos

Activos



Figura 1. Ejemplo de clasificación de activos según su naturaleza

Fuente: elaboración propia

Activos

Los activos se clasifican de acuerdo con el tipo de almacenamiento, los componentes que utilizan, etc. La clasificación de estos dependerá de la organización y las referencias que utilice para su identificación. En la figura 1 se muestra un ejemplo de clasificación de activos.

Una vez identificados los activos, deben clasificarse utilizando el proceso elegido por la organización.
Primero se define el tipo de activo: información, físico, servicios de TI, humanos. Esta no es la única clasificación, pero es la propuesta en el curso y la cual se tomará como referencia para la explicación.

Luego se realiza la ponderación (clasificación cualitativa y cuantitativa) para validar el grado de importancia del activo dentro de la organización. Pueden existir diferentes clasificaciones que expresan un nivel de importancia definido por la empresa: escalas del 1 al 5, como se muestra en la tabla 1, y del 1 al 3, como se muestra en la tabla 2, que se constituyen en las escalas de preferencia. Es importante que la descripción exprese realmente el valor del activo para la empresa con el fin de facilitar su identificación, puesto que dicho proceso lo realizará el encargado o dueño del activo.

Activos

Si en una misma tabla de identificación de activos incluimos una clasificación según su naturaleza y su valor, contamos con una descripción completa del activo, como se muestra en la tabla 3. Pueden existir más clasificaciones, como áreas de operación del activo, costo etc. y de acuerdo con dichas clasificaciones la definición del nivel varía. Para las tablas de los ejemplos, la consideración de valor se ha definido respecto a la operación de la empresa, es decir, qué tanto esta requiere dicho activo para operar.

Tabla 1. Clasificación de activos escala 1 a 5

Nivel	Descripción
5	Extremadamente importante: el activo es de suma importancia para la operación de toda la organización, la cual no puede operar si no está disponible.
4	Altamente importante: el activo es muy importante para áreas misionales en la organización. Estas áreas no pueden operar si no está disponible.
3	Importante: el activo es muy importante para áreas de apoyo dentro de la organización. Estas áreas no pueden operar si no está disponible.
2	Medianamente importante: el activo es importante para la organización; sin embargo, puede operar sin él durante un tiempo corto.
1	Mínimamente importante: el activo es importante para la organización; sin embargo, puede operar sin él durante un tiempo relativamente prolongado.

Fuente: elaboración propia

Activos

Tabla 2. Clasificación de activos escala 1 a 3

Nivel	Descripción
3	Altamente importante: el activo es de suma importancia para la operación de toda la organización. Esta no puede operar si no está disponible.
2	Medianamente importante: el activo es importante para la organización; sin embargo, puede operar sin él durante un tiempo corto.
1	Mínimamente importante: el activo es importante para la organización; sin embargo, puede operar sin él durante un tiempo relativamente prolongado.

Fuente: elaboración propia

Activos

Tabla 3. Clasificación completa del activo

Clase de activo	Entorno de TI global	Nombre del activo	Clasificación del activo	Ponderación
Tangible	Infraestructura física	Centro de datos	Extremadamente Importante	5
Tangible	Infraestructura física	Servidores	Extremadamente Importante	5
Tangible	Infraestructura física	Equipos de escritorio	Importante	3
Tangible	Infraestructura física	Equipos portátiles	Medianamente Importante	2
Tangible	Infraestructura física	Celulares	Medianamente Importante	2
Tangible	Infraestructura física	*Routers*	Extremadamente Importante	5
Tangible	Infraestructura física	*Switches*	Extremadamente Importante	5
Tangible	Infraestructura física	Medios extraíbles (por ejemplo, cintas, CD-ROM, DVD, discos duros, portátiles, dispositivos de almacenamiento PC Card, dispositivos de almacenamiento USB, etc.)	Altamente importante	4
Tangible	Reputación		Importante	3
Tangible	Buena voluntad		Importante	3
Tangible	Moral de empleados		Importante	3
Tangible	Productividad de empleados		Extremadamente Importante	5
Servicios de TI	Mensajería	Correo electrónico	Altamente Importante	4
Servicios de TI	Infraestructura básica	Protocolo de configuración dinámica de host (DHCP)	Extremadamente Importante	5
Servicios de TI	Infraestructura básica	Herramientas de configuración empresarial	Medianamente Importante	2

Activos

Clase de activo	Entorno de TI global	Nombre del activo	Clasificación del activo	Ponderación
Servicios de TI	Infraestructura básica	Uso compartido de archivos	Extremadamente Importante	5
Servicios de TI	Infraestructura básica	Almacenamiento de datos	Extremadamente Importante	5
Servicios de TI	Infraestructura básica	Acceso telefónico remoto	Poco Importante	1
Servicios de TI	Infraestructura básica	Telefonía	Poco Importante	1
Servicios de TI	Infraestructura básica	Acceso a red privada virtual (VPN)	Extremadamente Importante	5
Humanos	Personal de TI			2
Humanos	Proveedor			4
Humanos	Personal Operativo			5

Fuente: elaboración propia

Cada empresa decide, según la clasificación y ponderación de activos, sobre cuáles activos aplicará los controles. Para ello, se deben identificar vulnerabilidades, amenazas y riesgos de estos y entender a qué principio de seguridad afecta la posible materialización de un evento adverso, con el fin de mitigar efectivamente su impacto.

Como se recordará, los principios de la seguridad de la información son tres: disponibilidad, Integridad y Confidencialidad, los cuales se presentan en la figura 2. Proporcionar el cumplimiento a los activos garantiza el objetivo principal de la seguridad de la información. Veamos qué significa cada uno de estos principios.

Como se recordará, los principios de la seguridad de la información son tres: disponibilidad, Integridad y Confidencialidad, los cuales se presentan en la figura 2. Proporcionar el cumplimiento a los activos garantiza el objetivo principal de la seguridad de la información. Veamos qué significa cada uno de estos principios.

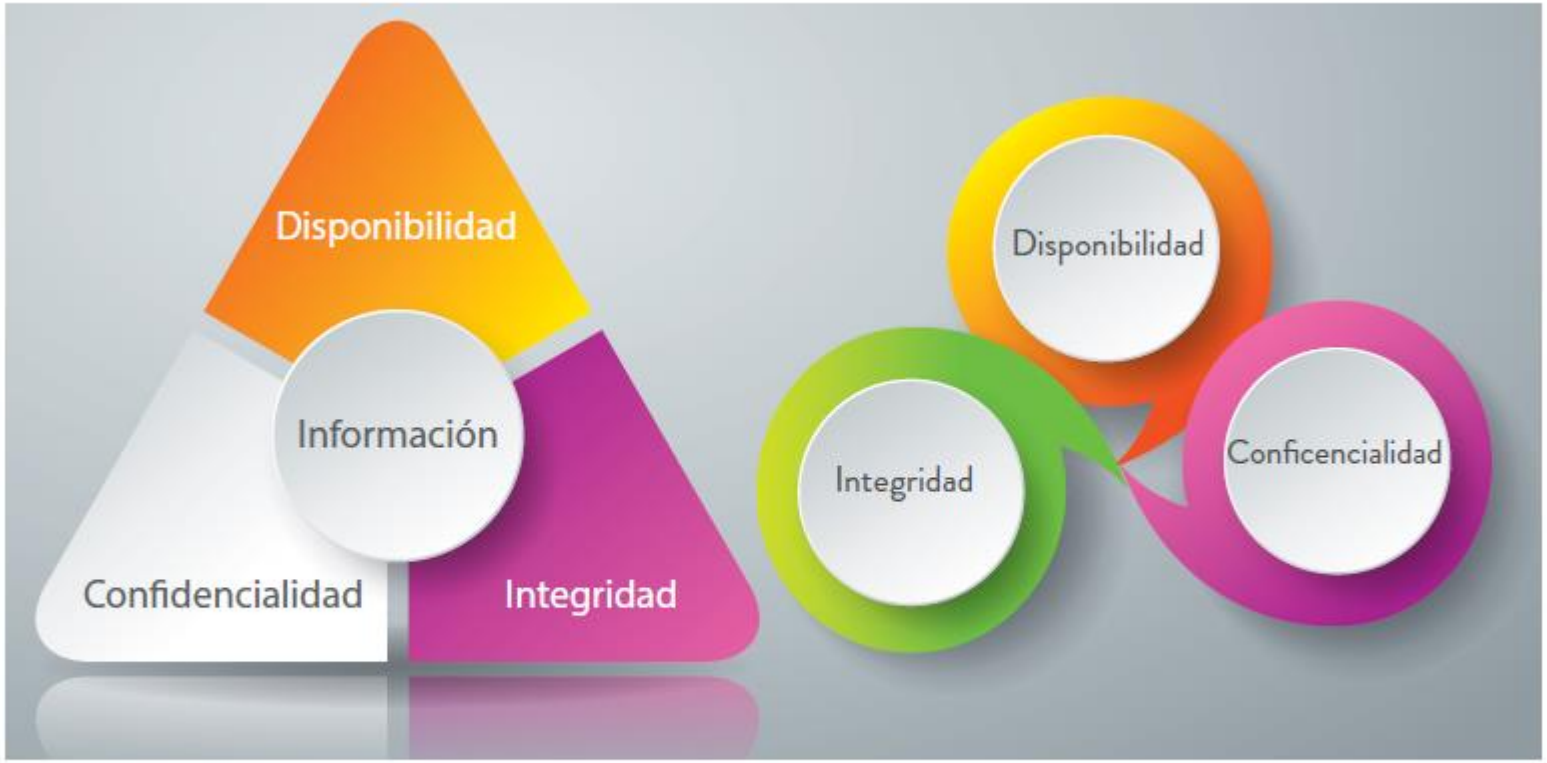


Figura 2. Principios de la seguridad de la información

Fuente: elaboración propia

Activos

La disponibilidad implica garantizar el acceso oportuno a la información que se requiera siempre y cuando cuente con autorización previa para acceder. Por dicha razón, las herramientas que se utilizan como medio de acceso (dispositivos de red, aplicaciones, computadores, personas, procesos etc.), deben contar con los recursos adecuados para funcionar de manera predecible y con un nivel de rendimiento aceptable, protegerse contra posibles interrupciones y, en caso de ser interrumpidos, estar en la capacidad de recuperarse de manera rápida y segura para que la operación de la empresa no se vea afectada de manera negativa (Harris, 2013).

Para alcanzar este objetivo es indispensable analizar la cantidad de elementos que intervienen en el proceso de acceso a un recurso. La red, por ejemplo, tiene muchas piezas que deben mantenerse en funcionamiento (routers, switches, servidores DNS, servidores DHCP, proxies, firewalls). De igual manera, el software cuenta con varios componentes que deben ejecutarse de manera saludable (sistema operativo, aplicaciones, software antimalware), las condiciones de entorno pueden afectar el acceso a dichos recursos (incendio, inundación, problemas eléctricos) y se pueden presentar posibles desastres naturales (terremoto, temblor) y robos o ataques físicos (Harris, 2013).

Ejemplos de controles

Toda empresa debe contar con un respaldo de sus archivos, puesto que el dispositivo de almacenamiento local en el cual se han creado puede fallar o ser atacado, sin permitir su acceso. Ataques como ransomware aprovechan esta debilidad de las empresas y, por tanto, al secuestrar la información, tienen la certeza de que los usuarios pagarán por ella, pues no poseen otra manera de recuperarla. Sin embargo, ¿qué significa el respaldo de datos?

El respaldo de datos es el proceso de copiar los elementos de información recibidos, transmitidos, almacenados, procesados y/o generados por un sistema en otros medios externos. Existen muchos mecanismos para tener respaldo, dependiendo de lo que se quiera asegurar; copias de la información en dispositivos de almacenamiento secundario y computadores paralelos ejecutando las mismas transacciones, son algunos ejemplos de este tipo de controles.

Aunque la organización cuente con un proceso automático para realizar dichas copias, es indispensable validar su funcionamiento con regularidad. Muchas empresas desconocen que su proceso presenta fallas hasta el momento que requieren hacer uso de alguna copia.

Ejemplos de controles

En la figura 3 se observan algunos dispositivos para guardar las copias. La recomendación general ha sido mantener respaldos locales y externos, de preferencia más de uno por cada tipo, determinando cuidadosamente el tiempo de permanencia de las copias y las transacciones simultáneas a realizar, de acuerdo con la operación de la empresa.



Figura 3. Medios de almacenamiento de información

Fuente: Freepik.com (2017)

Controles

Si el fallo se encuentra en algún elemento de operación, es decir, el incidente no se relaciona con el acceso a determinada información, sino con los medios que la almacenan o procesan (por ejemplo, falta de energía en el servidor de aplicaciones y, por tanto, falla en el acceso al sistema de información principal), es necesario contar con otra alternativa de acceso, o sea, tener definido un plan de contingencia para continuar la operación y recuperarse del incidente. Estos planes suelen ser una guía paso a paso, en la cual se definen cada uno de los procedimientos a seguir, sus responsables y las herramientas a considerar en caso de ser interrumpida parte o toda la operación de una empresa, con el objetivo de recuperarla. De acuerdo con las exigencias del plan, por el tipo de negocio, estos procedimientos pueden ser ejecutados por personas, sistemas informáticos o la combinación de estos elementos. En la figura 4 se presenta un esquema general con pasos sugeridos, puesto que un plan de recuperación de desastres está orientado al cumplimiento de continuidad del negocio, lo cual se constituye en toda una rama de estudio.

Controles



Figura 4. Ejemplo plan de contingencia y recuperación

Fuente: elaboración propia

Integridad

Este principio hace referencia a que la información debe ser fiable, certera y libre de manipulación por personal no autorizado. El hardware, el software y los elementos para la comunicación deben operar conjuntamente para preservar y procesar los datos correctamente o para transportar los mismos a los destinos, previamente indicados, sin ningún tipo de alteración. Los sistemas y la red deben estar protegidos contra intrusos o intervención externa. Los controles aplicables para cumplir con este principio garantizan que los atacantes o los errores de los usuarios no comprometan la integridad de los sistemas por acciones, tales como corrupción de archivos, modificación maliciosa, reemplazo de datos o falta de entrenamiento (Harris, 2013).

Los usuarios, muchas veces, afectan un sistema o la integridad de sus datos por error (aunque los usuarios internos también pueden cometer actos maliciosos). Por tal motivo, la seguridad no solo debe aplicar controles para el acceso, sino que también debe preocuparse por simplificar las acciones que los usuarios deben realizar en determinadas operaciones, de modo que los errores se vuelvan menos comunes (Harris, 2013).

Ejemplos de controles

En sistemas críticos, los archivos deben restringir la visualización y el acceso de los usuarios. Las aplicaciones deben proporcionar mecanismos que verifiquen valores de entrada válidos y razonables. Las bases de datos deben permitir que solo las personas autorizadas modifiquen los datos y los que están en tránsito deben estar protegidos por cifrado u otros mecanismos.

En general, la aplicación de controles para garantizar la integridad de los datos implica la ejecución de actividades preventivas, programación orientada al usuario y medidas de protección para el acceso a diferentes herramientas.



Figura 5. Protección de datos

Fuente: Makyzz (2017)

Confidencialidad

Este principio implica que la información mantiene un nivel de secreto y no todos los usuarios de la organización pueden acceder de manera indiscriminada a ella. Por el contrario, es necesario establecer niveles de privilegios para que solo las personas a cargo de la manipulación de información accedan a esta sin que un tercero no autorizado pueda intervenirla. Estos niveles de confidencialidad deben prevalecer mientras que los datos residen en sistemas y dispositivos dentro de la red a medida que se trasmiten y llegan a su destino.

Los atacantes pueden evitar los mecanismos de confidencialidad mediante el monitoreo de la red, robo de contraseñas, intervención de mecanismos de cifrado y la ingeniería social (lograr que un usuario final ejecute acciones que no realizaría si conociera sus consecuencias negativas y que pueden afectar la seguridad de la empresa, utilizando la manipulación y el engaño para tal fin) (Harris, 2013).

La confidencialidad se puede proporcionar mediante el cifrado de los datos tal como se almacenan y transmiten, aplicando un estricto control de acceso y clasificación de estos y capacitando al personal sobre los procedimientos adecuados de protección de datos.

Ejemplos de controles

La encriptación o cifrado de datos es el proceso que se sigue para enmascararlos con el objetivo de que sean incomprensibles para cualquier agente no autorizado. Esto se hace usando una clave especial y siguiendo una secuencia de pasos preestablecidos, conocida como “algoritmo de cifrado”. El proceso inverso se conoce como descifrado y devuelve los datos a su estado original.

En resumen, como se muestra en la figura 6, para garantizar el cumplimiento del objetivo principal de la seguridad de la información es importante considerar controles suficientes, orientados al almacenamiento, protección y cifrado de datos.



Figura 6. Resumen protección de datos

Fuente: Freepik (2015)

Definiciones complementarias a los principios

Existen otros conceptos de interés que complementan el objetivo principal de seguridad de la información.

Estos conceptos son autenticidad y no repudio.

La autenticidad

Tiene como objetivo asegurar la identidad de la información contenida en algún sistema, respecto a su origen y procedencia, con el fin de comprobar que dicha información proviene de la fuente que dice ser.

Por ejemplo, cuando recibimos un mensaje de correo electrónico de un dominio conocido, el control para cumplir con el parámetro de autenticidad es validar que efectivamente la fuente de dicho mensaje es el dominio que dice ser y no ha habido una suplantación del mismo con fines maliciosos.

No repudio o irrenunciabilidad

Indica que ni el emisor ni el receptor, en un proceso de comunicación, pueden afirmar que la información trasmitida no proviene de sus fuentes.

Si la autenticidad prueba quién es el emisor y autor de un correo y cuál es su destinatario, el “no repudio” prueba que el autor envió la comunicación (no repudio en origen) y que el destinatario la recibió (no repudio en destino).

Definiciones complementarias a los principios

El no repudio evita que el emisor o el receptor nieguen la transmisión de un mensaje. Así, cuando se envía un mensaje, el receptor puede comprobar que, efectivamente, el supuesto emisor lo envió. De forma similar, cuando se recibe un mensaje, el emisor puede verificar que, de hecho, el supuesto receptor lo recibió.

En la figura 7 podemos identificar la relación que existe entre los conceptos vistos. En primera instancia, la información debe estar disponible. Luego, debe garantizarse el acceso solo a personal autorizado y establecer medidas para evitar alternaciones en la información. Quienes intervienen en las transacciones no pueden negar haberlas hecho, siempre y cuando se hayan realizado las acciones pertinentes para su protección.

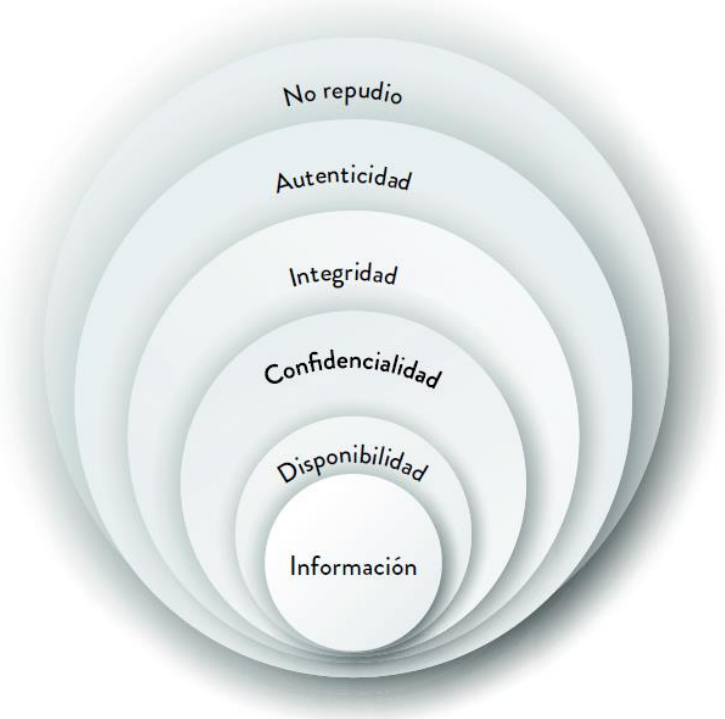


Figura 7. Relación de principios y conceptos complementarios en seguridad de la información

Fuente: elaboración propia

Vulnerabilidad

Hemos mencionado que la vulnerabilidad es intrínseca al activo u objeto de estudio, es decir, propio de su naturaleza. En términos empresariales podemos considerarla, además, como una falla de un equipo, persona o sistema que puede generar perjuicios en este o en los demás elementos que interactúen con él (ISO, 2009). Las principales causas de las vulnerabilidades en los sistemas de información se deben a:

- Debilidad en el diseño de los protocolos utilizados en las redes (FTP, SMTP, Telnet).
- Errores de programación, lo que justifica el uso continuo de parches.
- Configuración errónea de los sistemas de información o falla en la parametrización de estos.
- Políticas de seguridad deficientes o inexistentes.

En la tabla 4 se muestran ejemplos de vulnerabilidades comunes que se presentan en los diferentes tipos de activos de información de las empresas; son ejemplos generales para comprender los conceptos. En el ambiente empresarial este listado debe ser específico y según la clasificación de la información que se haya definido (Harris, 2013).

Amenaza

Una vez identificadas las vulnerabilidades, es importante definir qué factores externos pueden explotarlas, es decir, identificar la potencial ocurrencia de un evento adverso o no deseado debido a las vulnerabilidades del activo; o sea, lo que llamamos amenaza. Este evento puede producirse con diferentes grados de intensidad y duración, por lo cual el impacto varía (Harris, 2013).

Riesgo

Para las empresas lo primordial, en términos de seguridad, es estudiar los potenciales eventos adversos, con el fin de conocer la probabilidad de que ocurran. Esta probabilidad de ocurrencia es lo que se conoce como riesgo. En otras palabras, el riesgo es la posibilidad de que una amenaza explote una vulnerabilidad (Harris, 2013).

En la siguiente tabla se identifican las amenazas según las vulnerabilidades definidas según ISO 27005:

Tipo	Descripción Vulnerabilidad	Amenaza	Riesgo	Principio afectado
Hardware	Susceptibilidad a condiciones ambientales, tales como humedad, salinidad, polvo, etc.	Polvo, corrosión, congelamiento de los equipos o los medios	Destrucción parcial o total	Disponibilidad - Integridad
Hardware	Falta de trazabilidad de su ubicación	Manipulación no autorizada	Fuga de Información	Confidencialidad
Hardware	Mantenimiento insuficiente o con fallas	Incumplimiento en los procedimientos para el mantenimiento	Funcionamiento ineficiente	Disponibilidad - Integridad
Software	Falta de terminación de la sesión cuando se abandona la estación de trabajo	Abuso de los derechos	Fuga de Información	Confidencialidad
Software	Interface de usuario poco intuitiva o compleja	Error voluntario o involuntario en el uso	Indisponibilidad parcial o total del sistema	Disponibilidad - Integridad
Software	Fallas de programación	Corrupción de los datos	Indisponibilidad parcial o total del sistema	Disponibilidad - Integridad
RED	Tráfico sensible sin protección	Escucha subrepticia (escucha que se hace oculta con fines maliciosos)	Fuga de información	Confidencialidad
RED	Conexión deficiente de los cables	Falla del equipo de telecomunicaciones	Indisponibilidad parcial o total del sistema	Disponibilidad - Integridad
RED	Gestión inadecuada de la red	Saturación del sistema de información	Indisponibilidad parcial o total del sistema	Disponibilidad - Integridad
Personal	Ausencia del personal	Incumplimiento de l as obligaciones de la empresa	Indisponibilidad parcial o total del sistema	Disponibilidad - Integridad
Personal	Entrenamiento ineficiente en temas de seguridad	Error voluntario o involuntario en el uso	Fuga de Información	Confidencialidad Disponibilidad - Integridad
Personal	Trabajo no supervisado	Hurto de medios o documentos	Destrucción parcial o total	Confidencialidad
Espacio físico	Descuido en el control de acceso	Hurto de medios o documentos	Fuga de información	Disponibilidad - Integridad

Tipo	Descripción Vulnerabilidad	Amenaza	Riesgo	Principio afectado
Espacio físico	Ubicación en un lugar con inestabilidad energética	Pérdida del suministro de energía	Indisponibilidad parcial o total del sistema	Confidencialidad
Espacio físico	Fallas estructurales	Daño a las personas y equipos	Destrucción parcial o total	Disponibilidad - Integridad
Empresa	Falta o insuficiencia en los contratos con clientes, proveedores y personal interno referente a seguridad	Abuso de los derechos	Fuga de información	Confidencialidad
Empresa	Falta de procedimientos para control de cambios	Incumplimiento en la entrega de servicios]o productos	Indisponibilidad parcial o total del sistema	Disponibilidad - Integridad
Empresa	Falta de procedimientos del cumplimiento de derechos intelectuales	Uso de *software* ilegal	Destrucción parcial o total	Disponibilidad - Integridad

Fuente: **elaboración propia**

Ataques informáticos

Comprendidos los conceptos principales sobre seguridad de la información, es necesario aclarar un último término que es bastante utilizado en el medio de la seguridad y cuyo efecto se espera evitar:

Un ataque informático hace referencia a todo intento que se realiza para eludir los controles de seguridad en un sistema, cuyo propósito de evasión es comprometer el sistema con algún fin malicioso, es decir, afectar la disponibilidad, confidencialidad o integridad de la información (interrumpir la operación de un sistema, manipularlo para obtener algún tipo de ventaja que afecte a la organización, robar información etc.). Estos ataques son ideados por personas que utilizan sus conocimientos en informática para aprovechar las vulnerabilidades de un sistema.

La motivación de un atacante puede ser variada: Reconocimiento dentro de una comunidad por pertenecer a determinada ideología, venganza (empleado insatisfecho), simple curiosidad o interés en la materia, dinero, y hasta espionaje y terrorismo.

Un ataque activo se caracteriza porque su objetivo es alterar la integridad y disponibilidad de la información.

Un ataque pasivo se caracteriza porque su objetivo es interceptar la información, sin modificarla, afectando principalmente el principio de confidencialidad.

Ataques informáticos

Un ataque interno es iniciado por un agente interno dentro del perímetro de seguridad definido, es decir, personal autorizado para acceder a los recursos del sistema, pero los utiliza de una manera no aprobada por quienes le otorgaron la autorización.

Un ataque externo es un ataque iniciado desde fuera del perímetro por un usuario no autorizado o ilegítimo del sistema (un “extraño”). Este usuario puede acceder y lanzar el ataque con recursos internos, con el fin de evitar que se descubra el origen del ataque.



Ataques informáticos

Tabla 5. Resumen ataques informáticos más comunes

Ataque	Tipo	Descripción	Ejemplos
Scan	Pasivo	Su objetivo es escuchar y revisar algún punto (regularmente un puerto) de la víctima, con el fin de identificar datos relevantes que faciliten un posterior ataque. En este tipo de arremetida no hay intervención de los sistemas.	Port Scan, Idle Scan
Denial-of-service attack	Activo	Su objetivo es que el sistema de la víctima no se encuentre disponible o afectar su conectividad. Esto se logra gracias a la sobrecarga de solicitudes que debe atender el sistema durante el ataque, la afectación de los recursos computacionales y el gran consumo de ancho de banda que puede producir el ataque.	SYN Flood: intenta abrir conexiones TCP con direcciones falsas ICMP Flood: envía innumerables solicitudes de Ping UDP Flood: genera grandes cantidades de paquetes UDP hacia la víctima Smurt Attack
Spoofing	Activo	Su objetivo es engañar a la víctima, por lo cual se utilizan técnicas para falsificar la procedencia de los datos, es decir, hacerse pasar por una entidad válida para la víctima, por lo cual el atacante accede a un sistema e información confidencial, entre otros.	P, ARP, DNS, WEB, Email Spoofing, suplantación de cualquier protocolo

Ataques informáticos

Ataque	Tipo	Descripción	Ejemplos
Man in the middle	Activo	Su objetivo es intervenir una comunicación en secreto para manipularla y enviar información diferente a dos entidades, engañándolas, de tal manera que no saben que la comunicación ha sido afectada.	ARP Poisoning
Brute Force	Activo	Su objetivo es descubrir la contraseña de un sistema o aplicación, probando todas las posibles combinaciones hasta lograr el acceso.	Ataque puro o de diccionario
Social Engineering	Activo	Es la manipulación de las personas para convencerlas de que ejecuten acciones o actos que normalmente no realizarían y que revelan todo lo necesario para superar las barreras de seguridad.	*Phising*

Fuente: elaboración propia

NORMA TÉCNICA COLOMBIANA
NTC-ISO/IEC 27001
2022-11-09

Segunda actualización

Seguridad de la información, ciberseguridad y protección de la privacidad.
Sistemas de gestión de seguridad de la información. Requisitos

https://tienda.icontec.org/gp-tecnicas-de-seguridad-ampliacion-de-las-ntc-iso-iec-27001-y-gtc-iso-iec-27002-para-la-gestion-de-la-privacidad-de-la-informacion-requisitos-y-directrices-ntc-iso-iec27701-2020.html

https://www.iso.org/es/contents/data/standard/08/28/82875.html

NTC-ISO-IEC 27701:2020

Técnicas de seguridad. Ampliación de las NTC-ISO/IEC 27001 y GTC-ISO-IEC 27002 para la gestión de la privacidad de la información. Requisitos y directrices.

Security techniques. Extension to iso/iec 27001 and ISO/IEC 27002 for privacy information management. Requirements and guidelines.

Estado **VIGENTE**

Vista Previa

En este documento se especifican los requisitos y se ofrece orientación para establecer, implementar, mantener y mejorar continuamente un Sistema de Gestión de la Privacidad de la Información (SGPI) en forma de una ampliación de las NTC-ISO/IEC 27001 y GTC-ISO/IEC 27002 para la gestión de la privacidad en el contexto de la organización. Este documento especifica los requisitos relacionados con el SGPI y proporciona orientación para los controladores y procesadores de la IIP que tienen la responsabilidad y la rendición de cuentas del procesamiento de IIP. Este documento es aplicable a todos los tipos y tamaños de organizaciones, incluyendo compañías públicas y privadas, entidades gubernamentales y organizaciones sin ánimo de lucro, que son controladores y/o procesadores de la IIP que procesan IIP dentro de un SGPI.

Opciones de compra

Impreso COP$312.500

eBook Ilimitado x COP$250.000

(-20%) **COP$450.000**

Agregar al carrito

Paga a crédito con **Addi** en **hasta 6 cuotas.**
Revisa si calificas

Artículos relacionados para compra junto con este producto

GTC-ISO-IEC 27004:2022

Tecnología de la información. Técnicas de seguridad. Gestión de la seguridad de la información. Monitoreo, medición, análisis y evaluación

ISO/IEC 27001:2022

Information security, cybersecurity and privacy protection

Information security management systems

Requirements

No disponible en español

Estado : **Publicado**

Formato	Idioma
✓ PDF + ePub	Inglés
PDF + ePub + versión comparada	Inglés
Papel	Inglés

CHF 129

Añadir al carrito

Convertir Franco suizo (CHF) a tu moneda

¿Qué es la norma ISO/IEC 27001?

La ISO/IEC 27001 es la norma más conocida del mundo para **sistemas de gestión de la seguridad de la información (SGSI)**. Esta norma define los requisitos que debe cumplir un SGSI.

La norma ISO/IEC 27001 proporciona a las empresas de cualquier tamaño y de todos los sectores orientaciones para establecer, implantar, mantener y mejorar de manera continua un sistema de gestión de



Preview

Previsualice esta norma en nuestra Plataforma de navegación en línea (OBP)

NORMA TÉCNICA COLOMBIANA

NTC-ISO/IEC 27001

2022-11-09

Segunda actualización

Seguridad de la información, ciberseguridad y protección de la privacidad. Sistemas de gestión de seguridad de la información. Requisitos

E: Information security, cybersecurity and privacy protection. Informationsecurity management systems. Requirements

CORRESPONDENCIA: esta Norma Técnica Colombiana es idéntica (IDT) por traducción (IDT) de la norma ISO/IEC 27001:2022 y está cubierta por los derechos de autor y otros derechos de propiedad intelectual de la IEC, según el acuerdo de licencia con esta entidad.

DESCRIPTORES: sistemas de gestión; gestión; seguridad de la información; técnicas de seguridad; ciberseguridad; controles de seguridad.

I.C.S.: 03.100.70; 35.030

® ICONTEC 2022

Reservados todos los derechos. Ninguna parte de esta publicación puede ser reproducida o utilizada en cualquier forma o por cualquier medio, electrónico o mecánico incluyendo fotocopiado y microfilmación, sin permiso por escrito del editor.

Editada por ICONTEC. Numeral 14237 Bogotá, D.C. – Tel. (571) 6078888

Prohibida su reproducción | Editada 2022-11-09

NORMA TÉCNICA COLOMBIANA

NTC-ISO/IEC 27001



Referencias

Harris, S. (2013). All in One CISSP Exam Guide. New York: McGraw-Hill.

INTERNATIONAL ORGANIZATION FOR STANDARDIZATION (ISO). (2009). Information Technology. SecurityTechniques. Information Security Management Systems. Overview and vocabulary. Geneva: ISO.

Real Academia Española (RAE) (2017). Diccionario de la lengua española. Recuperado de http://dle.rae.es/?id=LXrOqrN

Freepik. (2015). Resumen protección de datos [Vectores]. Recuperado de https://www.freepik.es/vector-gratis/banderas-de-cifrado-de-datos_768935.htm#term=encrypteddata&page=1&position=6

Macrovector - Freepik.com. (2017). Medios de almacenamiento de información [Vectores]. Recuperado de https://www.freepik.es/vector-gratis/iconos-sobre-almacenamiento-dedatos_1008315.htm#term=data storage&page=1&position=18

Makyzz - Freepik.com. (2017). Protección de datos [Vectores]. Recuperado de https://www.freepik.es/vector-gratis/concepto-de-seguridad-de-datos_1063670.htm#term=encrypteddata&page=1&position=1

pss.mex.net. (s.f.). Ejemplo plan de contingencia y recuperación [Infografía]. Recuperado de https://blogrecursosytecnologia.com/category/plan-de-recuperacion-ante-desastres/

Referencias

Bloomua. (s.f.). Activos de información [Vectores]. Recuperado de https://es.123rf.com/search.php?word=activo+de+informacion&srch_lang=es&imgtype=&Submit=+&t_word=&t_lang=es&orderby=0&sti=msyslo637vyd4rvp98|&mediapopup=31672130

Fancycravel. (s.f.). Valor [Fotografía]. Recuperado de https://pixabay.com/es/ipad-comprimidotecnolog%C3%ADa-contacto-820272/

Geralt. (s.f.). Datos [Fotografía]. Recuperado de https://pixabay.com/es/social-medios-decomunicaci%C3%B3n-1989152/

Geralt. (s.f.). Orden [Fotografía]. Recuperado de https://pixabay.com/es/social-medios-decomunicaci%C3%B3n-1989152/

Geralt. (s.f.). Veracidad [Fotografía]. Recuperado de https://pixabay.com/es/cadena-articuladapersonales-2850276/

Jemastock. (s.f.). Riesgo materializado [Vectores]. Recuperado de https://www.freepik.es/vectorpremium/pirata-informatico-robando-cuentas-hackeo-dinero_2451045.htm

kalhh. (s.f.). Control de virus [Fotografía]. Recuperado de https://pixabay.com/es/equipo-virustroyano-programa-1446108/

UNIVERSIDAD COOPERATIVA DE COLOMBIA

VIGILADA MINEDUCACIÓN

Gracias

rodrigo.carreno@campusucc.edu.co